

Mission 10

Mise en Place d'un Système SIEM

Wazuh + ELK Stack, détection d'intrusions, conformité RGPD

Contexte

Déploiement d'un SIEM complet basé sur Wazuh et ELK Stack pour la collecte centralisée des événements de sécurité, la détection des menaces en temps réel, la réponse aux incidents et la conformité réglementaire.

Architecture SIEM

Composant	Version	Serveur / IP
Wazuh Manager	4.7+	SRV-SIEM : 172.20.0.30
Elasticsearch	8.x	SRV-SIEM (8 Go RAM dédié)
Kibana	8.x	SRV-SIEM (accès https://siem)
Logstash	8.x	SRV-SIEM (normalisation logs)
Wazuh Agent	4.7+	Tous serveurs + postes clés

Étapes de Mise en Place

Déploiement de Wazuh Manager + ELK Stack, installation des agents et configuration des règles de détection.

Étape 1 — Préparation du serveur SIEM (Debian 12)

- ▶ Préparer une VM dédiée avec 8 Go RAM et 200 Go SSD (172.20.0.30)
- ▶ Configurer les variables système pour Elasticsearch (mémoire JVM)
- ▶ Désactiver le swap pour les performances Elasticsearch
- ▶ Ouvrir les ports nécessaires dans le pare-feu local

Commandes / Configuration :

```
# Augmenter la limite vm.max_map_count pour Elasticsearch :
echo 'vm.max_map_count=262144' >> /etc/sysctl.conf
sysctl -p

# Désactiver le swap :
swapoff -a
sed -i '/ swap / s/^/#/' /etc/fstab

# Firewall - ports Wazuh :
ufw allow 1514/tcp # Wazuh agent
ufw allow 1515/tcp # Wazuh registration
ufw allow 9200/tcp # Elasticsearch (LAN only)
ufw allow 5601/tcp # Kibana
```

✓ **Résultat attendu :** Le serveur est prêt pour l'installation. `vm.max_map_count = 262144` confirmé.

Étape 2 — Installation de la stack Wazuh + ELK

- ▶ Ajouter le dépôt officiel Wazuh et ELK à APT
- ▶ Installer Wazuh Manager, Elasticsearch, Kibana et Logstash

- ▶ Démarrer et activer tous les services
- ▶ Vérifier que Wazuh Manager est opérationnel

Commandes / Configuration :

```
# Ajout dépôt Wazuh :
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | gpg --dearmor >
/usr/share/keyrings/wazuh.gpg
echo 'deb [signed-by=/usr/share/keyrings/wazuh.gpg]
https://packages.wazuh.com/4.x/apt/ stable main' >
/etc/apt/sources.list.d/wazuh.list
apt update

apt install wazuh-manager elasticsearch kibana logstash -y

systemctl enable --now wazuh-manager elasticsearch kibana logstash

# Vérification :
/var/ossec/bin/wazuh-control status
```

✓ **Résultat attendu :** Wazuh Manager est actif. Elasticsearch répond sur le port 9200. Kibana est accessible.

Étape 3 — Déploiement des agents Wazuh

- ▶ Installer l'agent Wazuh sur tous les serveurs Linux et Windows
- ▶ Configurer chaque agent pour pointer vers le Wazuh Manager (172.20.0.30)
- ▶ Enregistrer les agents auprès du Manager
- ▶ Vérifier que les agents apparaissent dans l'interface Kibana (Wazuh > Agents)

Commandes / Configuration :

```
# Installation agent Linux (sur SRV-LINUX-01) :
apt install wazuh-agent -y
WAZUH_MANAGER='172.20.0.30' WAZUH_AGENT_NAME='SRV-LINUX-01' dpkg -i wazuh-agent*.deb
systemctl enable --now wazuh-agent

# Installation agent Windows (PowerShell admin) :
Invoke-WebRequest -Uri 'https://packages.wazuh.com/4.x/windows/wazuh-agent-
4.7.x.msi' -OutFile wazuh-agent.msi
msiexec /i wazuh-agent.msi WAZUH_MANAGER='172.20.0.30' WAZUH_AGENT_NAME='SRV-WIN-01'
/quiet
net start WazuhSvc
```

✓ **Résultat attendu :** Tous les agents sont connectés et apparaissent en vert dans Kibana > Wazuh > Agents.

Étape 4 — Configuration des règles de détection

- ▶ Activer les règles de détection de force brute SSH et RDP
- ▶ Créer des règles personnalisées pour détecter les modifications d'objets AD
- ▶ Configurer la surveillance d'intégrité des fichiers (FIM) sur les répertoires critiques
- ▶ Activer les règles de conformité RGPD et PCI-DSS intégrées à Wazuh

Commandes / Configuration :

```
# /var/ossec/etc/rules/local_rules.xml :
<group name='stadiumcompany,'>
  <rule id='100001' level='10'>
    <if_matched_sid>5710</if_matched_sid>
    <same_source_ip />
    <description>Brute force SSH détecté depuis la même IP</description>
  </rule>

  <rule id='100002' level='12'>
    <if_group>windows</if_group>
    <match>EventID: 4728</match>
```

```

    <description>Ajout d'un membre à un groupe AD privilégié</description>
  </rule>
</group>

# FIM - surveillance /etc et /var/ossec :
# Dans ossec.conf : <directories
check_all='yes'>/etc,/usr/bin,/usr/sbin</directories>

```

✓ **Résultat attendu :** Les alertes apparaissent dans Kibana lors des tentatives de force brute ou de modification AD.

Étape 5 — Configuration des tableaux de bord Kibana et alertes

- ▶ Importer les dashboards Wazuh pré-construits dans Kibana
- ▶ Configurer les alertes email via le module de notification Wazuh
- ▶ Créer une intégration avec GLPI pour la création automatique de tickets sécurité
- ▶ Configurer la rétention des logs (12 mois actif, archivage automatique)

Commandes / Configuration :

```

# Configuration notifications email dans ossec.conf :
<global>
  <email_notification>yes</email_notification>
  <smtp_server>mail.stadiumcompany.com</smtp_server>
  <email_from>wazuh@stadiumcompany.com</email_from>
  <email_to>soc@stadiumcompany.com</email_to>
  <email_maxperhour>12</email_maxperhour>
  <email_alert_level>10</email_alert_level>
</global>

# Politique de rétention Elasticsearch (ILM) :
# Hot: 30 jours | Warm: 90 jours | Cold: 12 mois | Delete: 36 mois

```

✓ **Résultat attendu :** Le SOC reçoit les alertes par email. Kibana affiche les tableaux de bord de sécurité en temps réel.

Étape 6 — Rapports de conformité et audit RGPD

- ▶ Activer les modules de conformité Wazuh (RGPD, PCI-DSS, HIPAA)
- ▶ Générer un premier rapport de conformité RGPD depuis Kibana
- ▶ Programmer la génération mensuelle automatique et l'envoi au DPO
- ▶ Documenter les procédures de réponse aux incidents de sécurité

Commandes / Configuration :

```

# Dans Kibana (Wazuh > Regulatory Compliance) :
# Activer : GDPR, PCI DSS

# Script de rapport mensuel :
0 7 1 * * /opt/wazuh-reports/generate-compliance-report.py --format pdf --send-to
dpo@stadiumcompany.com

# Vérification conformité RGPD :
# Article 32 : chiffrement, intégrité, disponibilité → couvert par VPN + SIEM
# Article 33 : notification violation dans 72h → procédure documentée

```

✓ **Résultat attendu :** Le rapport de conformité RGPD est généré. Les obligations légales sont tracées et documentées.